

Esercizio 6: Estrarre un eseguibile da un PCAP

Obiettivi

- **Parte 1** - Analizzare **Log** e Cature di **Traffico** Pre-catturati
- **Parte 2** - Estrarre File Scaricati dal **PCAP**



Parte 1 - Analizzare Log e Cature di Traffico Pre-catturati

Nella Parte 2, lavorerai con il file **nimda.download.pcap**. Catturato in un laboratorio precedente, `nimda.download.pcap` contiene i pacchetti relativi al download del malware **Nimda**. La tua versione del file, se l'hai creata nel laboratorio precedente e non hai reimportato la tua VM CyberOps Workstation, è memorizzata nella directory `/home/analyst`. Tuttavia, una copia di quel file è anche memorizzata nella VM CyberOps Workstation, sotto la directory **`/home/analyst/lab.support.files/pcaps`** in modo che tu possa completare questo laboratorio.

Per coerenza dell'output, il laboratorio utilizzerà la versione memorizzata nella directory **`pcaps`**. Sebbene `tcpdump` possa essere usato per analizzare i file catturati, l'interfaccia grafica di Wireshark rende il compito molto più semplice.

È anche importante notare che **`tcpdump`** e Wireshark condividono lo stesso formato di file per le cature di pacchetti; pertanto, i file PCAP creati da uno strumento possono essere aperti dall'altro.

Cambia directory nella cartella **support.files/pcaps**, e ottieni un elenco dei file usando il comando `ls -l`.

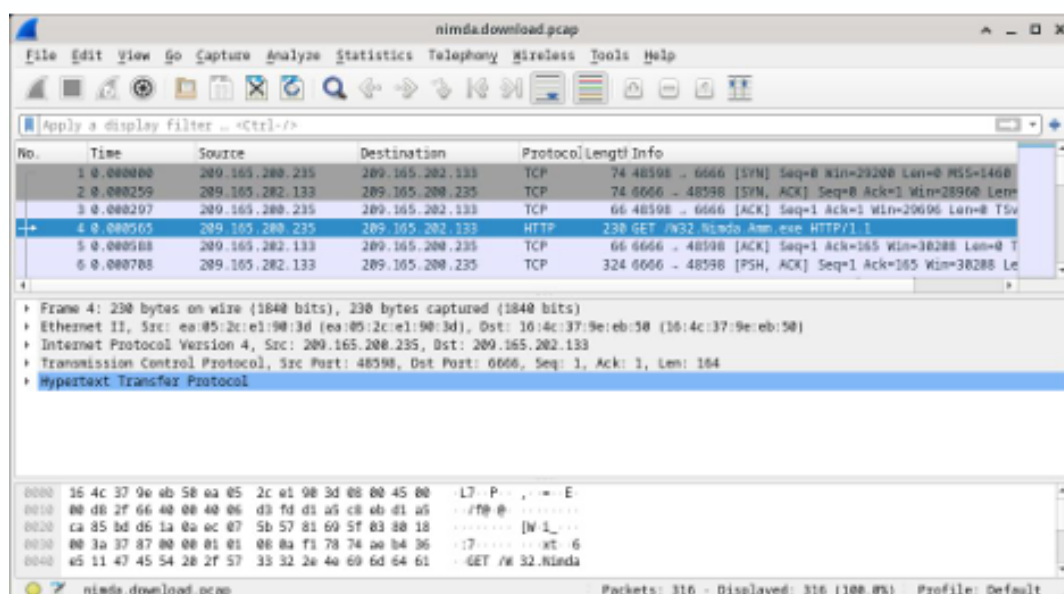
```
[analyst@secOps ~]$ cd lab.support.files/pcaps
[analyst@secOps pcaps]$ ls -l
total 7460
-rw-r--r-- 1 analyst analyst 3510551 Aug  7 15:25 lab_prep.pcap
-rw-r--r-- 1 analyst analyst  371462 Jun 22 10:47 nimda.download.pcap
-rw-r--r-- 1 analyst analyst 3750153 May 25 11:10
wannacry_download_pcap.pcap
[analyst@secOps pcaps]$
```

Esegui il comando sottostante per aprire il file **nimda.download.pcap** in Wireshark

Nota: l'originale diceva 'download.pcap', ho corretto in 'nimda.download.pcap').

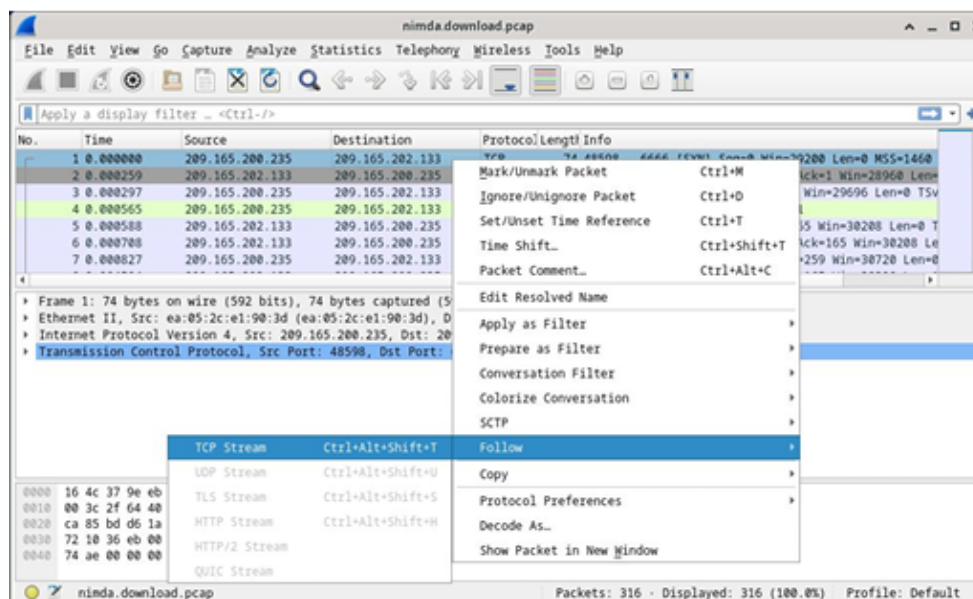
```
[analyst@secOps pcaps]$ wireshark nimda.download.pcap &
```

Il file **nimda.download.pcap** contiene la cattura dei pacchetti relativa al download del malware eseguito in un laboratorio precedente. Il pcap contiene tutti i pacchetti inviati e ricevuti mentre **tcpdump** era in esecuzione. Seleziona il quarto pacchetto nella cattura ed espandi l'**Hypertext Transfer Protocol** per visualizzare come mostrato sotto.

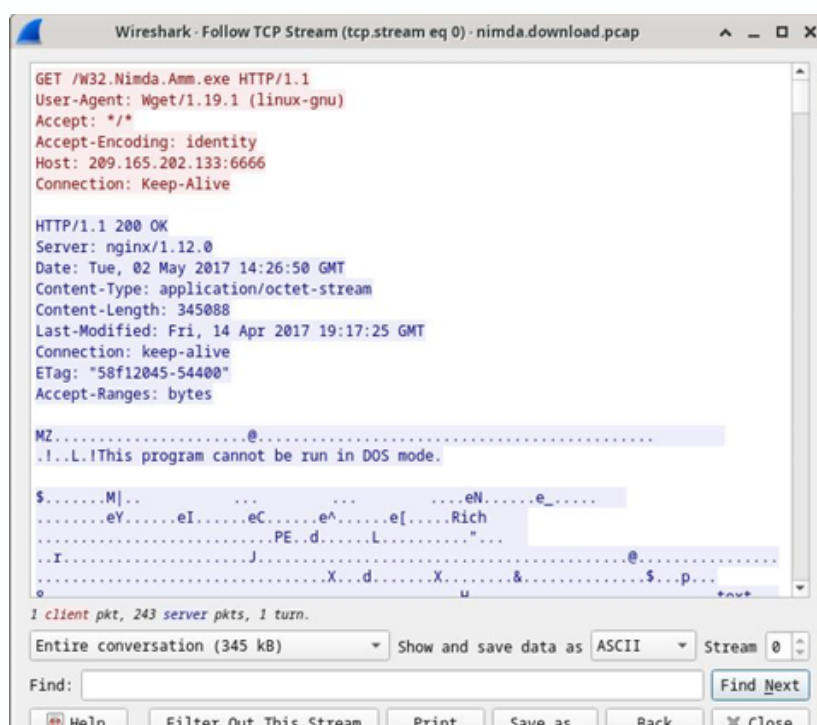


I pacchetti da uno a tre sono **l'handshake TCP**. Il quarto pacchetto mostra la richiesta per il file malware. Confermando ciò che era già noto, la richiesta è stata fatta tramite HTTP, inviata come richiesta **GET**.

Poiché HTTP viene eseguito su **TCP**, è possibile utilizzare la funzione Follow TCP Stream di Wireshark per ricostruire la transazione TCP. Seleziona il primo pacchetto TCP nella cattura, un pacchetto **SYN**. Fai clic con il pulsante destro del mouse su di esso e scegli Follow > **TCP Stream**.



Wireshark visualizza un'altra finestra contenente i dettagli per l'intero **flusso** TCP selezionato.





Cosa sono tutti quei simboli mostrati nella finestra Follow TCP Stream? Sono rumore di connessione? Dati? Spiega. Ci sono alcune parole leggibili sparse tra i simboli. Perché sono lì?

Quei simboli rappresentano i dati binari grezzi (raw data) del file eseguibile che è stato scaricato.

La finestra "**Follow TCP Stream**" mostra l'intera conversazione tra il client (chi scarica) e il server. La comunicazione HTTP è divisa in due parti:

Header: La prima parte, (es. GET /W32.Nimda.Amm.exe HTTP/1.1, HTTP/1.1 200 OK, Content-Type: application/octet-stream), contiene le informazioni di controllo della comunicazione.

Body: La seconda parte, separata dagli **header** da una riga vuota, è il contenuto vero e proprio del file richiesto. Poiché un file .exe non è un file di testo, **Wireshark** lo visualizza come una sequenza di simboli e caratteri non stampabili, che è la rappresentazione testuale dei suoi byte.

Le parole leggibili che si vedono sparse tra i simboli (come MZ all'inizio e la famosa frase This program cannot be run in **DOS mode**) non sono casuali. Fanno parte della struttura standard di un file eseguibile per Windows (formato PE - Portable Executable):

MZ: Sono le "**Magic Bytes**" (lettere iniziali del programmatore Mark Zbikowski) che identificano il file come un eseguibile MS-DOS.

This program cannot be run in DOS mode: È un messaggio standard contenuto nel cosiddetto "DOS stub", una piccola parte del file che viene eseguita se si tenta di lanciare il programma in un vecchio ambiente DOS.

PE: Indica l'inizio dell'header **PE** (Portable Executable), che contiene le informazioni necessarie a Windows per eseguire il file.



Nonostante il nome W32.Nimda.Amm.exe, questo eseguibile non è il famoso worm. Per motivi di sicurezza, questo è un altro file eseguibile che è stato rinominato come W32.Nimda.Amm.exe. puoi dire quale eseguibile sia realmente?

L'eseguibile è molto probabilmente il Calcolatore di Windows (**calc.exe**), rinominato in **W32.Nimda.Amm.exe** per simulare lo scenario di analisi di un malware.

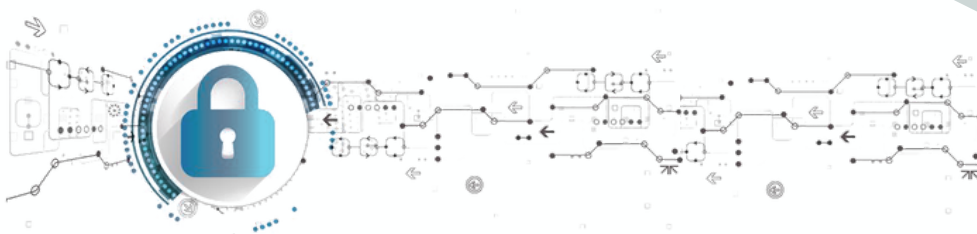
Usando i frammenti di parole visualizzati dal Follow TCP Stream di Wireshark, questi sono gli elementi che fanno pensare al calc.exe:

MZ: Le iniziali del programmatore Mark Z., che indicano l'inizio di un file eseguibile per DOS/Windows.

This program cannot be run in DOS mode.: Una frase standard inserita in quasi tutti i programmi per Windows.

PE: Indica l'inizio dell'header "Portable Executable", la struttura fondamentale dei file .exe di Windows.

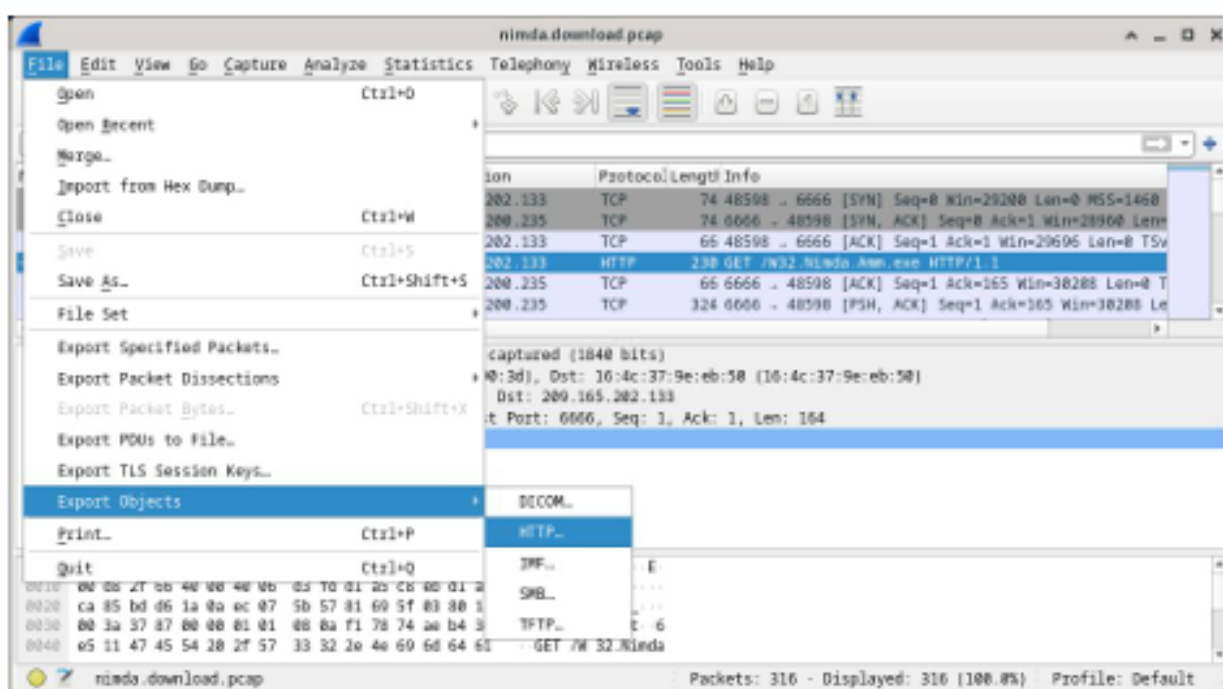
Rich: Una firma lasciata dal compilatore di Microsoft



Parte 2 - Estrarre File Scaricati dal PCAP

Poiché i file di cattura contengono tutti i pacchetti relativi al traffico, un **PCAP** di un download può essere utilizzato per recuperare un file scaricato in precedenza. Segui i passaggi sottostanti per usare Wireshark per recuperare il malware **Nimda**.

In quel quarto pacchetto nel file **nimda.download.pcap**, nota che la richiesta HTTP GET è stata generata da 209.165.200.235 a 209.165.202.133. La colonna Info mostra anche che questa è di fatto la richiesta **GET** per il file. b. Con il pacchetto della richiesta GET selezionato, naviga su File > Export Objects > HTTP, dal menu di Wireshark.

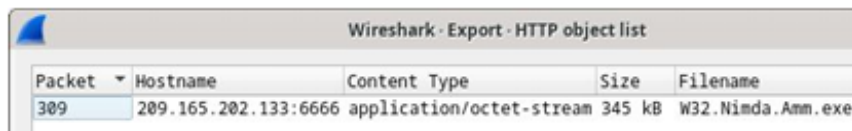


Wireshark visualizzerà tutti gli oggetti **HTTP** presenti nel flusso **TCP** che contiene la richiesta **GET**. In questo caso, solo il file **W32.Nimda.Amm.exe** è presente nella cattura. Ci vorranno alcuni secondi prima che il file venga visualizzato. □Nota: il nome file originale era 'Nimda.Amm.exe', ma l'immagine e il contesto suggeriscono 'W32.Nimda.Amm.exe'. Ho usato quest'ultimo per coerenza).



Perché W32.Nimda.Amm.exe è l'unico file nella cattura?

Perché la cattura del traffico di rete (**nimda.download.pcap**) è stata creata in un lasso di tempo predefinito, registrando unicamente l'azione del download di quel singolo file.



Packet	Hostname	Content Type	Size	Filename
309	209.165.202.133:6666	application/octet-stream	345 kB	W32.Nimda.Amm.exe

Nella finestra **HTTP object list**, seleziona il file **W32.Nimda.Amm.exe** e fai clic su **Save As** nella parte inferiore dello schermo. e. Fai clic sulla freccia sinistra finché non vedi Home. Fai clic su Home e poi sulla cartella **analyst** (non la scheda analyst). **Salva** il file lì.

Torna alla finestra del terminale e assicurati che il file sia stato salvato. Cambia directory nella cartella **/home/analyst** ed elenca i file nella cartella usando **ls -l**.

```
[analyst@secOps pcaps]$ cd /home/analyst
[analyst@secOps ~]$ ls -l
total 364
drwxr-xr-x 2 analyst analyst 4096 Sep 26 2014 Desktop
drwx----- 3 analyst analyst 4096 May 25 11:16 Downloads
drwxr-xr-x 2 analyst analyst 4096 May 22 08:39 extra
drwxr-xr-x 8 analyst analyst 4096 Jun 22 11:38 lab.support.files
drwxr-xr-x 2 analyst analyst 4096 Mar 3 15:56 second_drive
-rw-r--r-- 1 analyst analyst 345088 Jun 22 15:12 W32.Nimda.Amm.exe
[analyst@secOps ~]$
```

Il comando file fornisce informazioni sul **tipo** di file. Usa il comando **`file`** per saperne di più sul malware, come mostrato sotto:

```
[analyst@secOps ~]$ file W32.Nimda.Amm.exe
W32.Nimda.Amm.exe: PE32+ executable (console) x86-64, for MS Windows
[analyst@secOps ~]$
```

Come visto sopra, **W32.Nimda.Amm.exe** è di fatto un file eseguibile di Windows.



Nel processo di analisi del malware, quale sarebbe un probabile passo successivo per un analista di sicurezza?

Dopo aver estratto con successo il file eseguibile (W32.Nimda.Amm.exe) dal traffico di rete, un analista di sicurezza procederebbe con i seguenti passi, operando sempre in un ambiente sicuro e isolato per evitare infezioni accidentali:

1. **Calcolare l'Hash del File:** Il primo passo è generare un'impronta digitale unica del file (usando algoritmi come MD5, SHA-1, SHA-256).

- Scopo: Questo hash permette di cercare il file su database online di threat intelligence come **VirusTotal**, **Hybrid Analysis** o **Any.run**. Se il file è un malware noto, si otterranno immediatamente informazioni sulla sua natura, pericolosità e indicatori di compromissione (**IOCs**).

1. **Analisi Statica:** Analizzare il file senza eseguirlo.

- Uso del comando strings: Per estrarre tutte le stringhe di testo leggibili dal file **binario**. Questo può rivelare URL, indirizzi IP, nomi di file, comandi o messaggi **sospetti**.
- Analisi dell'**Header PE**: Utilizzare strumenti specifici per esaminare gli header del file. Questo rivela le **librerie** e le funzioni che il programma intende usare (es. funzioni per la connessione di rete, per la modifica del registro di sistema, per la manipolazione di file), fornendo **importanti** indizi sulle sue capacità.

1. **Analisi Dinamica** (Sandboxing): Eseguire il file in un ambiente **controllato** e monitorarne il comportamento.

- Scopo: **Osservare** cosa fa effettivamente il programma una volta in esecuzione.
- Cosa monitorare:
 - **Connessioni** di rete: Tenta di contattare server esterni? Se sì, quali?
 - Modifiche al **file system**: Crea, modifica o cancella file?
 - Modifiche al **registro di sistema**: Tenta di ottenere persistenza o di modificare la configurazione del sistema?
 - **Processi creati**: Lancia altri processi o si inietta in processi legittimi?

L'obiettivo finale è comprendere appieno il funzionamento della minaccia per sviluppare regole di rilevamento (es. per antivirus o firewall) e procedure di bonifica efficaci.